

Mapeo Normativo Detallado – Métricas GQM/PRAGMATIC

1. Introducción

Este documento relaciona cada métrica TRIKE definida mediante GQM con los requisitos normativos principales (NIS2, guías ENISA, marco legal español de ciberseguridad y referencias complementarias).
[web:23][web:41][web:44]

2. Tabla de mapeo

Código Métrica	Descripción	Dimensión TRIKE	Referencias normativas / marcos	Comentario
T1.1.a	Incidentes de ciberseguridad por 100.000 hab. y sector	Threat	NIS2 art. 23 (gestión y notificación de incidentes), ENISA Threat Landscape, guías nacionales de reporte (INCIBE, CCN-CERT) [web:23][web:22] [web:46]	Facilita análisis de exposición por sector y territorio, clave para planes nacionales.
T1.1.b	Incidentes significativos NIS2 por tipo de entidad	Threat	NIS2 art. 3–4 (ámbito y entidades), art. 23–30 (notificación y supervisión), Anteproyecto Ley Coordinación y Gobernanza [web:17][web:41] [web:44]	Métrica central para supervisores nacionales y para la UE.
T1.2.a	% incidentes atribuidos a APT/eCrime	Threat	ENISA Threat Landscape, NIS2 (enfoque basado en riesgo y amenazas avanzadas) [web:46][web:23]	Informativa para priorizar capacidades de defensa avanzada y cooperación internacional.
T1.2.b	% ataques malware-free / IA	Threat	ENISA, informes de mercado sobre tendencias de ataque, guías NIS2 sobre gestión de riesgos emergentes [web:13][web:46] [web:43]	Orienta inversiones en detección basada en comportamiento e IA.

T1.3.a	Incidentes derivados de proveedores críticos	Threat	NIS2 art. 21.2(d) (seguridad de la cadena de suministro), ENISA supply chain guidance [web:23][web:43]	Directamente vinculado a la obligación de gestionar riesgos de terceros.
T1.3.b	% vulns de cadena de suministro SW	Threat	NIS2, guías sobre gestión de vulnerabilidades y SBOM, marcos de desarrollo seguro [web:23]	Apoya políticas nacionales sobre software crítico y dependencia de terceros.
R1.1.a	Pérdida económica esperada por 1.000 M€ VA	Risk	NIS2 art. 21 (gestión de riesgos), ENISA technical guidance (evaluación de riesgo e impacto) [web:23][web:43]	Alinea análisis de riesgo con impacto macroeconómico sectorial.
R1.2.a	% entidades con riesgo cuantitativo	Risk	ENISA guidance, buenas prácticas (FAIR), NIS2 (criterios de riesgo) [web:23] [web:25]	Indica grado de sofisticación en la gestión de riesgos, relevante para supervisión.
R1.3.a	Ratio incidentes/entidad por categoría	Risk	NIS2 art. 2–3, clasificación de entidades, informes nacionales de ciberseguridad [web:17][web:16]	Facilita priorización de inspecciones y programas de apoyo.
R1.3.b	Pérdida media por incidente	Risk	ENISA, guías de gestión de incidentes y continuidad, prácticas de mercado de ciberseguro [web:23][web:22]	Apoya la estimación de riesgos residuales y la planificación de coberturas.

I1.1.a	Duración media de indisponibilidad	Impact	NIS2 art. 21, 23 (continuidad de servicios esenciales), ENISA BCM guidance [web:23] [web:43]	Métrica clave de resiliencia y continuidad, de alto interés para reguladores sectoriales.
I1.2.a	Coste medio de incidentes	Impact	NIS2 (proporcionalidad de medidas), análisis de impacto, guías de supervisión [web:23][web:16]	Permite sopesar el coste de no actuar vs. coste de medidas.
I1.2.b	P90/P95 impacto de incidentes graves	Impact	Marcos de riesgo financiero y de seguros, NIS2 (riesgos de alta magnitud) [web:23]	Complementa medias, capturando colas de distribución relevantes para resiliencia.
I1.3.a	Nº usuarios/ciudadanos afectados	Impact	NIS2, RGPD (afectación a interesados), guías de notificación de brechas [web:23] [web:22]	Métrica políticamente sensible y central para la confianza digital.
I1.3.b	Nº y cuantía de sanciones	Impact	NIS2 art. 34-36 (sanciones), RGPD (régimen sancionador) [web:44]	Refleja el grado de cumplimiento y la severidad de incumplimientos.
K1.1.a	% entidades con threat intel formal	Knowledge	NIS2 art. 21 (uso de inteligencia de amenazas implícito en gestión de riesgos), ENISA guidance [web:23] [web:40]	Indica capacidad de anticipación y madurez en gestión proactiva.
K1.2.a	% incidentes con post-mortem documentado	Knowledge	ENISA guidance (lecciones aprendidas, mejora continua), ISACA threat-led programs [web:25][web:23]	Métrica de cultura de aprendizaje y de calidad de gestión de incidentes.

K1.3.a	Profesionales cert. /100.000 hab.	Knowledge	ECSF, NIS2 (capacidades y formación), políticas de talento [web:40] [web:16]	Refleja disponibilidad de capacidades estructurales para cumplir obligaciones.
K1.3.b	Ratio vacantes/puestos ECSF	Knowledge	ECSF, estrategias nacionales de capacidades digitales [web:40]	Mide la brecha de talento como riesgo sistémico.
E1.1.a	% entidades con revisión anual de controles/modelo s	Evaluation	NIS2 art. 21 (políticas y procedimientos de evaluación de eficacia), ENISA guidance [web:23] [web:43]	Directamente alineada con la obligación de revisar la eficacia de medidas.
E1.2.a	% entidades con alto alineamiento NIS2	Evaluation	NIS2, Anteproyecto Ley Coordinación y Gobernanza [web:41][web:44]	Termómetro de cumplimiento percibido, a contrastar con hallazgos objetivos.
E1.2.b	Nº hallazgos de supervisión por categoría	Evaluation	NIS2 art. 29-32 (supervisión y enforcement) [web:44][web:43]	Métrica dura del estado real de cumplimiento y de la presión supervisora.
E1.3.a	% entidades que vinculan auditoría a recursos	Evaluation	NIS2 (gobernanza y responsabilidad de dirección), buenas prácticas de gobierno corporativo [web:41][web:16]	Indica si las auditorías cambian la realidad o solo generan informes.